MOVEBIT
Securing the Move Ecosystem

Cetus Token Smart Contract **Audit Report**

https://twitter.com/movebit_

contact@movebit.xyz

Cetus Token Smart Contract Audit Report



1 Executive Summary

1.1 Project Information

Description	A token protocol that supports conversion between Cetus and xCetus.
Type	Token
Auditors	MoveBit
Timeline	Apr 21, 2023 – Apr 26, 2023
Languages	Move
Platform	Sui
Methods	Architecture Review, Unit Testing, Manual Review
Source Code	https://github.com/CetusProtocol/cetus-token
Commits	a89e1b353df7403dd59fb110611f5a95ce2cf73a a8548cc7a39cfaabe3076a473cdd5ae09d7252e0

1.2 Files in Scope

The following are the SHA1 hashes of the last reviewed files.

ID	Files	SHA-1 Hash
LOC	xcetus/sources/lock_coin.move	afc8d98b8636640673884590 68400d1a886deb8b

LOK	xcetus/sources/locking.move	e882de7482416a1f20cf2a1c8cda196d9c48e34a
XRT	xcetus/sources/router.move	31287c0b5ee7913bc7cb52cdbbd83956a94a3480
UTL	xcetus/sources/utils.move	fbe1d7bd13db2566946a2c0e0374e90b258c6e51
XCT	xcetus/sources/xcetus.move	094fe2eb748e5061bfa2bc542a0aac39cf1e3d33
CTS	cetus/sources/cetus.move	15986b7635bfccbc7f3d3ae9af2b94cdc6ce365d
XMT	cetus/Move.toml	45ed0b36bf85fccd414645a6ca9c77ff2db63184
CMT	xcetus/Move.toml	b67bc4acc47f6cb54cf04d2501b3645348ad6597

1.3 Issue Statistic

Item	Count	Fixed	Acknowledged
Total	6	5	1
Informational	2	2	0
Minor	1	1	0
Medium	2	1	1
Major	1	1	0
Critical	0	0	0

1.4 MoveBit Audit BreakDown

MoveBit aims to assess repositories for security-related issues, code quality, and compliance with specifications and best practices. Possible issues our team looked for included (but are not

limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Integer overflow/underflow by bit operations
- Number of rounding errors
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting
- Unchecked CALL Return Values
- The flow of capability
- Witness Type

1.5 Methodology

The security team adopted the "**Testing and Automated Analysis**", "**Code Review**" and "**Formal Verification**" strategy to perform a complete security test on the code in a way that is closest to the real attack. The main entrance and scope of security testing are stated in the conventions in the "Audit Objective", which can expand to contexts beyond the scope according to the actual testing needs. The main types of this security audit include:

(1) Testing and Automated Analysis

Items to check: state consistency/ failure rollback/ unit testing/ value overflows/ parameter verification / unhandled errors/ boundary checking/ coding specifications.

(2) Code Review

The code scope sees in section **1.2**.

(3) Formal Verification

Perform formal verification for key functions with the Move Prover.

(4) Audit Process

- Carry out relevant security tests on the testnet or the mainnet;
- If there are any questions during the audit process, communicate with the code owner in time. The code owners should actively cooperate (this might include providing the latest stable source code, relevant deployment scripts or methods, transaction signature scripts, exchange docking schemes, etc.);
- The necessary information during the audit process will be well documented for both the audit team and the code owner in a timely manner.

2 Summary

This report has been commissioned by **Cetus Token** to identify any potential issues and vulnerabilities in the source code of the **Cetus Token** smart contract, as well as any contract dependencies that were not part of an officially recognized library. In this audit, we have utilized various techniques, including manual code review and static analysis, to identify potential vulnerabilities and security issues.

During the audit, we identified **6** issues of varying severity, listed below.

ID	Title	Severity	Status
LOK-01	Multiple instances of `LockUpManager` can be initialized	Medium	Fixed
LOK-02	Unnecessary function execution caused by order of assert in `redeem_treasury` function	Informational	Fixed
LOK-03	Redundant logic in the `burn` function	Informational	Fixed
LOK-04	Meaningless 0-value CETUS transfer in `convert` function	Minor	Fixed

CTS-01	Inappropriate sharing of metadata during `CETUS` coin registration.	Major	Fixed
CTS-02	Lack of proper management of CETUS token minting and burning permissions.	Medium	Acknowledged

3 Findings

LOK-01 Multiple instances of `LockUpManager` can be initialized

Severity: Medium

Status: Fixed
Code Location: xcetus/sources/locking.move, L222.
Descriptions: Multiple instances of `LockUpManager` can be initialized, which is not unique and may cause problems.
Suggestion: Restrict the initialization of `LockUpManager` to a single instance to prevent potential issues caused by multiple instances. Alternatively, if multiple instances of `LockUpManager` are required, ensure that they are properly managed and do not interfere with each other.

Resolution: The client followed our suggestion and fixed this issue.

LOK-02 Unnecessary function execution caused by order of assert in `redeem_treasury` function

Severity: Informational

Status: Fixed
Code Location: xcetus/sources/locking.move, L443.
Descriptions: The assert in the `redeem_treasury` function is checked after the `take_treasury` function, which can cause unnecessary execution depth when the assert fails.
Suggestion: Modify the `redeem_treasury` function to check the assert before calling the `ta`

`ke_treasury` function. This will reduce the execution depth when the assertion fails and improve code efficiency.

Resolution: The client followed our suggestion and fixed this issue.

LOK-03 Redundant logic in the `burn` function

Severity: Informational

Status: Fixed
Code Location: xcetus/sources/locking.move, L443.
Descriptions: In the `burn` function, the values of `amount` and `value` are always equal, so the logic to check both `amount` and `value` is redundant.

Suggestion: Remove the redundant logic in the `burn` function to improve code clarity and reduce the risk of confusion or errors caused by unnecessary code. This can be achieved by removing the check for `value` and only checking the `amount`.

Resolution: The client followed our suggestion and fixed this issue.

LOK-04 Meaningless 0-value CETUS transfer in `convert` function

Severity: Minor

Status: Fixed
Code Location: xcetus/sources/locking.move, L276.
Descriptions: In the `convert` function, when converting `CETUS` to `XCETUS`, if the remaining value of `CETUS` after conversion is `0`, it is destroyed instead of being transferred.
Suggestion: Modify the `convert` function to destroy `CETUS` instead of transferring it when the remaining value is 0 after `CETUS` conversion. This will ensure that `CETUS` is processed correctly.

Resolution: The client followed our suggestion and fixed this issue.

CTS-01 Inappropriate sharing of metadata during `CETUS` coin registration.

Severity: Major

Status: Fixed

Code Location: cetus-token/cetus/sources/cetus.move, L33.

Descriptions: The metadata of registering `CETUS` coins should be frozen instead of shared, which does not comply with the process of registering coins on Sui.

Suggestion: Modify the registration process of `CETUS` coin to freeze the metadata instead of sharing it. This will ensure compliance with the registration process on Sui.

Resolution: The client followed our suggestion and fixed this issue.

CTS-02 Lack of proper management of `CETUS` token minting and burning permissions.

Severity: Medium

Status: Acknowledged

Code Location: cetus-token/cetus/sources/cetus.move, L34.

Descriptions: The minting and burning permissions of `CETUS` tokens are by default transferred to the account of the contract deployer, which means that the contract deployer can freely issue and destroy `CETUS` tokens.

Suggestion: It is recommended to use a multi-signature account to manage token minting and burning permissions to avoid potential errors that may occur with a single-signature account or the loss of private keys resulting in the loss of token management permissions.

Resolution: The client has thought about this, and will use a multi-signature account to manage the minting and burning permissions in the future when there is a mature multi-signature application.

Appendix 1

Issue Level

- **Informational** issues are often recommendations to improve the style of the code or to optimize code that does not affect the overall functionality.
- **Minor** issues are general suggestions relevant to best practices and readability. They don't

post any direct risk. Developers are encouraged to fix them.

- **Medium** issues are non-exploitable problems and not security vulnerabilities. They should be fixed unless there is a specific reason not to.
- **Major** issues are security vulnerabilities. They put a portion of users' sensitive information at risk, and often are not directly exploitable. All major issues should be fixed.
- **Critical** issues are directly exploitable security vulnerabilities. They put users' sensitive information at risk. All critical issues should be fixed.

Issue Status

- **Fixed:** The issue has been resolved.
- **Acknowledged:** The issue has been acknowledged by the code owner, and the code owner confirms it's as designed, and decides to keep it.

Appendix 2

Disclaimer

This report is based on the scope of materials and documents provided, with a limited review at the time provided. Results may not be complete and do not include all vulnerabilities. The review and this report are provided on an as-is, where-is, and as-available basis. You agree that your access and/or use, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your own risk. A report does not imply an endorsement of any particular project or team, nor does it guarantee its security. These reports should not be relied upon in any way by any third party, including for the purpose of making any decision to buy or sell products, services, or any other assets. TO THE FULLEST EXTENT PERMITTED BY LAW, WE DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, IN CONNECTION WITH THIS REPORT, ITS CONTENT, RELATED SERVICES AND PRODUCTS, AND YOUR USE, INCLUDING BUT NOT LIMITED TO THE IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, NOT INFRINGEMENT.

MOVEBIT

Securing the Move Ecosystem



https://twitter.com/movebit_



contact@movebit.xyz